

典型协议攻击分析

The Request for Better Measurement: A Comparative Evaluation of 2FA Schemes (ASIACCS 2016)

汪 定

南开大学 密码与网络空间安全学院

2025年5月15日

Outline

□ Introduction

□ Preliminaries

- System architecture
- Adversary model
- Evaluation criteria

□ A taxonomy of smart-card-loss attacks

□ Attacks on representative schemes

- On Li et al.'s scheme
- On Kumari-Khan's scheme
- On Odelu et al.'s scheme
- On Muhaya's scheme

□ Conclusion

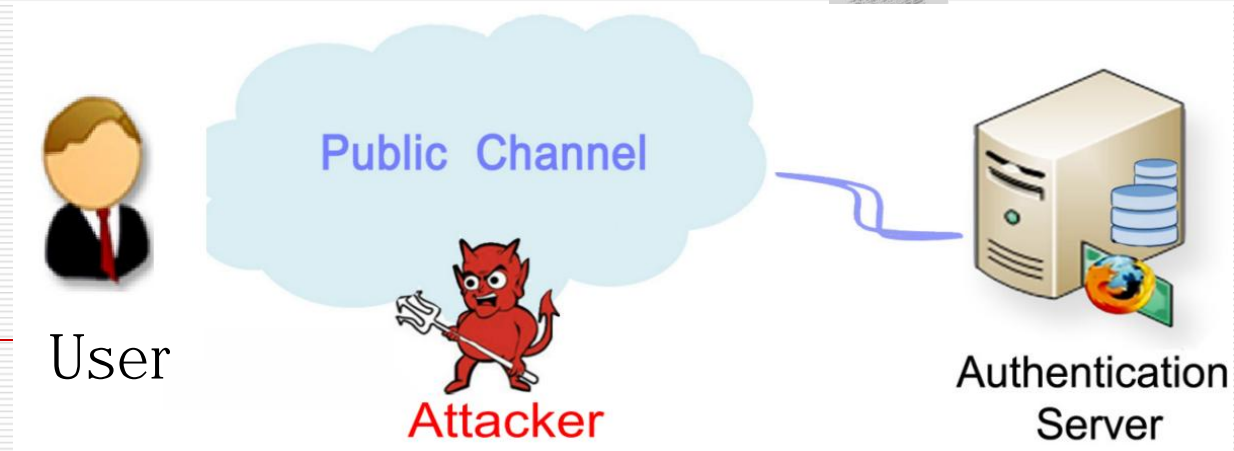


Introduction

□ User authentication

- A process to verify whether someone is with the claimed identity.
- Basic techniques:
 - (1) what a user knows, such as passwords, PINs;
 - (2) what a user has, such as smart cards, tokens;
 - (3) what a user is, such as fingerprints;

123456



Password-based authentication

- ❑ The most prevalent authentication method
 - ❑ In the 2000s, it is widely believed that passwords will be replaced by some other techniques.
 - ❑ Since 2010, there has been wide disillusionment.
 - ❑ Today, we are faced with the same problem that confronted us twenty years ago.
-

Some inherent problems with passwords

❑ Selection of popular passwords

how popular are our passwords?

TABLE II
TOP 10 MOST POPULAR PASSWORDS OF EACH DATASET

Rank	Tianya	7k7k	Dodonew	178	CSDN	Duowan	Rockyou	Yahoo	Phpbb
1	123456	123456	123456	123456	123456789	123456	123456	123456	123456
2	111111	0	a123456	111111	12345678	111111	12345	password	password
3	000000	111111	123456789	zz12369	11111111	123456789	123456789	welcome	phpbb
4	123456789	123456789	111111	qiulaobai	dearbook	123123	password	ninja	qwerty
5	123123	123123	5201314	123456aa	00000000	000000	iloveyou	abc123	12345
6	123321	5201314	123123	wmsxie123	123123123	5201314	princess	123456789	12345678
7	5201314	123	a321654	123123	1234567890	123321	123321	12345678	letmein
8	12345678	12345678	12345	000000	88888888	a123456	rockyou	sunshine	111111
9	666666	12345678	000000	qq66666	11111111	suibian	12345678	princess	1234
10	111222tianya	wangyut2	123456a	w2w2w2	147258369	12345678	abc123	qwerty	123456789
Sum of top10	2,297,505	440,300	533,285	793,132	670,881	338,012	669,126	4,476	7,135
Total accounts	30,901,241	5,423,287	16,258,891	9,072,965	6,428,277	4,982,730	32,581,870	442,834	255,373
Percent of top10	7.43%	8.12%	3.28%	8.74%	10.44%	6.78%	2.05%	1.01%	2.79%

❑ Password leakage

- Server compromise (2000+ popular sites leaked last year)
- Shoulder-surfing, Key-logging, malwares and Trojan horse

How to enhance password-based authentication

□ Two solutions

- Password + Token
- TPAKE+ LRPS



- 1) Threshold PAKE to prevent sever-side leakage
- 2) leakage-resilient password systems (LRPS) to prevent user-side leakage

NEW!

At NDSS 2012, Yan et al. showed that LRPS is inherently infeasible without incorporating certain trusted devices.



Smart-card-based password authentication

- ❑ Essential aim: ensuring two-factor security



Challenges (continue)

□ Have to reconcile many design goals

Table 2: Security requirements

SR1	Resistance to DoS attack
SR2	Resistance to impersonation attack
SR3	Resistance to parallel session attack
SR4	Resistance to password guessing attack
SR5	Resistance to replay attack
SR6	Resistance to smart card loss attack;
SR7	Resistance to stolen-verifier attack
SR8	Resistance to reflection attack
SR9	Resistance to insider attack

Table 3: Desirable attributes

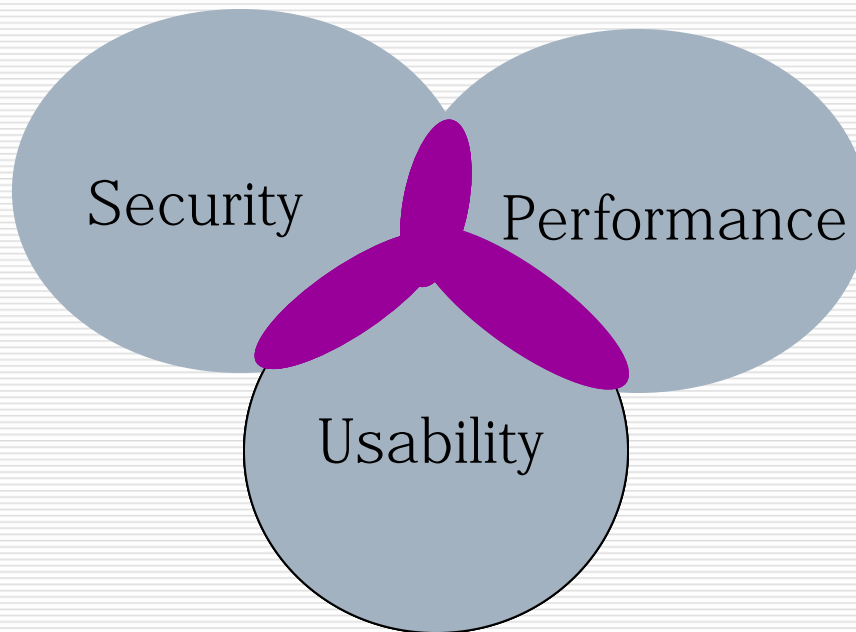
DA1	No password-related verifier table
DA2	Freely user password choice
DA3	No password reveal
DA4	Password dependent
DA5	Mutual authentication
DA6	Session key agreement
DA7	Forward secrecy
DA8	User anonymity
DA9	Smart card revocation
DA10	Efficiency for wrong password login

TABLE V. PERFORMANCE COMPARISON

	Protocol rounds ^a	Computation overhead		Communication cost		Storage cost
		User side	Server side	User side	Server side	
Xu et al. (2009) [35]	2	$3T_E+5T_H \approx 481.305$ ms	$3T_E+4T_H \approx 8.615$ ms	1408 bits	1408 bits	3200 bits
Jiang et al. (2015) [63]	2	$4T_E+4T_H \approx 609.044$ ms	$2T_E+4T_H \approx 5.744$ ms	2304 bits	1152 bits	3328 bits
Truong et al. (2015) [64]	3	$T_C+7T_H \approx 525.327$ ms	$3T_C+7T_H \approx 30.775$ ms	640 bits	1152 bits	384 bits
Our scheme	3	$3T_E+9T_H \approx 530.349$ ms	$3T_E+7T_H \approx 8.617$ ms	1536 bits	1152 bits	3616 bits

Challenges (continue)

- ❑ Trade-offs
- ❑ Conflicts



Contributions of this paper

- ❑ We revisit 19 improvements over Xu et al.'s 2009 scheme and show most of them are lack of fair, thorough measurement.
 - ❑ We show that some criteria in the evaluation metric are unworkable due to a number of ambiguities and redundancies.
 - ❑ We show that there are at least 8 different types of strategies for smart-card-loss-attack.
 - ❑ We provide an evaluation of 26 two-factor schemes based on the refined metric.
-

Outline

- Introduction
 - System model, attacker model and metric
 - A taxonomy of smart-card-loss attacks
 - Attack on previous schemes
 - Conclusion
-

System architecture

- ❑ User U is with a password and a smartcard.
- ❑ Server S stores some info (no password) about U .
- ❑ Server S may be with a public-private key pair (pk, sk).
- ❑ User U and server S share some parameters through the smartcard.

ID	Role	Reg time	...
example1	employee	2014-03-01	⋮
example2	manager	2015-02-01	⋮
⋮	⋮	⋮	⋮



Adversarial model

□ powerful adversary $\mathcal{A}$



(1) Have full control of the communication channel

(2) May either

Table I. Basic information about the twelve datasets (“PWs” stands for passwords)

Dataset	Application	Language	When leaked	How leaked	Total PWs	Unique PWs
Tianya	Social forum	Chinese	Dec. 4, 2011	Hacker breached	30,233,633	12,614,676
odonew	Gaming& Ecommerce	Chinese	Dec. 3, 2011	Hacker breached	16,231,271	11,236,220
CSDN	Programming	Chinese	Dec. 2, 2011	Hacker breached	6,428,287	4,037,610
Duowan	Gaming	Chinese	Dec. 1, 2011	Insider disclosed	4,982,740	3,119,070
Myspace	Social forum	English	Oct. 1, 2006	Phishing attack	41,545	37,144
ngle.org	Dating	English	Oct. 1, 2010	Query string injection	16,250	12,234
nwriters	Writer forum	English	Mar. 1, 2009	SQL injection	9,709	8,347
Hack5	Hacker forum	English	July 1, 2009	Hacker breached	2,987	2,351
Rockyou	Gaming	English	Dec. 07, 2009	Hacker breached	32,603,388	14,341,564
Yahoo	Web portal	English	July 12, 2012	SQL injection	453,492	342,515
Mail.ru	Email	Russian	Sep. 09, 2014	Phishing&malware	4,938,663	2,954,907
ndex.ru	Search engine	Russian	Sep. 09, 2014	Phishing&malware	1,261,810	717,203

Evaluation metric

- ❑ Security goals
- ❑ Desirable features
- ❑ Performance
 - Computation cost
 - Communication cost
 - Storage cost

Table 2: Security requirements

SR1	Resistance to DoS attack
SR2	Resistance to impersonation attack
SR3	Resistance to parallel session attack

Table 3: Desirable attributes

SR	DA1	No password-related verifier table
SR	DA2	Freely user password choice
SR	DA3	No password reveal
SR	DA4	Password dependent
SR	DA5	Mutual authentication
SR	DA6	Session key agreement
	DA7	Forward secrecy
	DA8	User anonymity
	DA9	Smart card revocation
	DA10	Efficiency for wrong password login

Defects in the metric

□ Ambiguities [Wang et al. IEEE TDSC'15]

- DA1: no password-related verifier table



DA1-Weak, DA1-Strong

- DA2: freely user password choice



DA2-Local-Insecure, DA2-Local-Secure , DA2-Interactive

- DA8: User anonymity



DA8-Weak , DA8-Strong

- ~~SR6 and other security requirements (discussed later)~~

Defects in the metric(2)

□ Redundancies

- $DA4 \subset SR6$

SR6 Resistance to smart card loss attack;

DA4 Password dependent

- $DA3 \subset SR9$

SR9 Resistance to insider attack

DA3 No password reveal

Outline

- Introduction
 - System model, attacker model and metric
 - A taxonomy of smart-card-loss attacks
 - Attack on previous schemes
 - Conclusion
-

SR6: Resist smart-card-loss attack

□ Explication

- SR6 relates to any attacker who has gained the victim's smart card
- All the other 8 security requirements deal with an attacker without the victim's smartcard.

□ Classificaton

Table 4: A taxonomy of smart-card-loss attacks (PW stands for password)

Smart-card-loss attack types		Need to Extract card	Need to return extracted card	# of online interactions	Weaknesses exploited	Design goals breached	Typical reference
Passive	Type I	No	Yes	0	No verification when PW change	Usability	Sec. 3.2.2 of [46]
	Type II	Yes	No	0	Definite verifier for PW change	Two-factor security	Sec. 3.2.2 this work
	Type III	Yes	No	0	Partition of non-group PWs	Two-factor security	Sec. 3.5 of [53]
	TYPE IV	Yes	No	0	Protocol flow 1	Two-factor security	Sec. 3.2.1 this work
	Type V	Yes	Yes	0	Protocol flow 2, pre-computation	Two-factor security, semantic security	Sec. 3.2 and 3.4 of [15]
	Type VI	Yes	Yes	0	Protocol flow 1, pre-computation	Two-factor security	Sec. 3.2.1 of [46]
Hybrid	Type VII	Yes	No	1 with S	Protocol flow 2	Two-factor security	Sec. 5.2.2 this work
	Type VIII	Yes	Yes	1 with U	Protocol flow 3	Two-factor security	Sec. 4.2 of [47]

SR6: smart-card-loss attack (2)

□ Highlights

- We, for the first time, show that there are at least 8 kinds of smart-card-loss-attacks.
- This also make the measurement of SR6 to be more fine-grained.

Table 4: A taxonomy of smart-card-loss attacks (PW stands for password)

Smart-card-loss attack types		Need to Extract card	Need to return extracted card	# of online interactions	Weaknesses exploited	Design goals breached	Typical reference
Passive	Type I	No	Yes	0	No verification when PW change	Usability	Sec. 3.2.2 of [46]
	Type II	Yes	No	0	Definite verifier for PW change	Two-factor security	Sec. 3.2.2 this work
	Type III	Yes	No	0	Partition of non-group PWs	Two-factor security	Sec. 3.5 of [53]
	TYPE IV	Yes	No	0	Protocol flow 1	Two-factor security	Sec. 3.2.1 this work
	Type V	Yes	Yes	0	Protocol flow 2, pre-computation	Two-factor security, semantic security	Sec. 3.2 and 3.4 of [15]
	Type VI	Yes	Yes	0	Protocol flow 1, pre-computation	Two-factor security	Sec. 3.2.1 of [46]
Hybrid	Type VII	Yes	No	1 with S	Protocol flow 2	Two-factor security	Sec. 5.2.2 this work
	Type VIII	Yes	Yes	1 with U	Protocol flow 3	Two-factor security	Sec. 4.2 of [47]

Outline

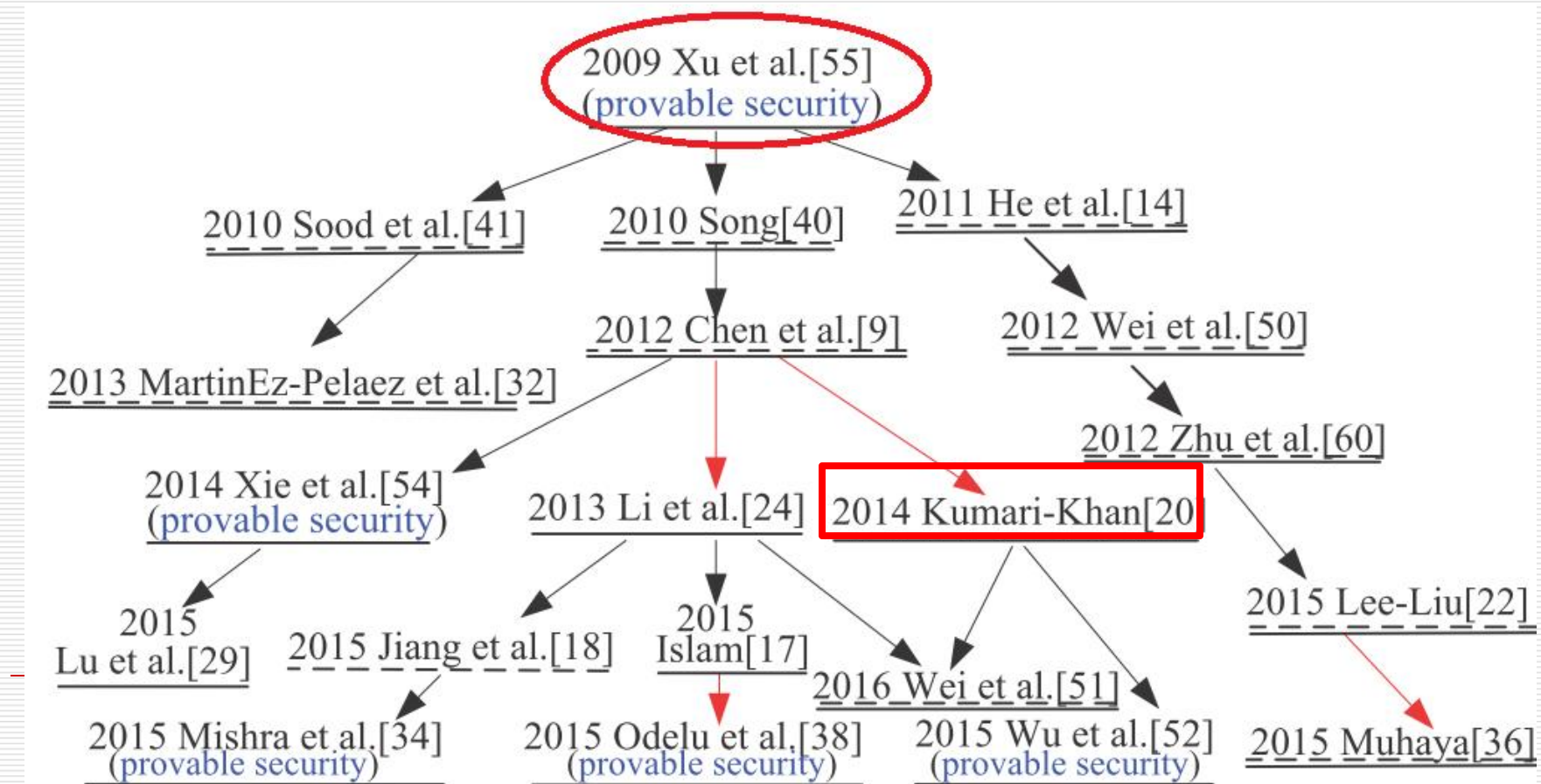
- Introduction
 - System model, attacker model and metric
 - A taxonomy of smart-card-loss attacks
 - Attacks on representative schemes**
 - Conclusion
-

Notations and abbreviations

Symbol	Description
U_i	i^{th} user
S	remote authentication server
$\mathcal{A}$	malicious attacker
ID_i	identity of user U_i
PW_i	password of user U_i
x	the secret key of remote server S
$\oplus$	the bitwise XOR operation
$\parallel$	the string concatenation operation
$h(\cdot)$	collision free one-way hash function
$\rightarrow$	a common channel
$\Rightarrow$	a secure channel

Revisting 19 improvements over Xu et al.'s scheme in 2009

- Using Kumari-Khan's scheme for presentation



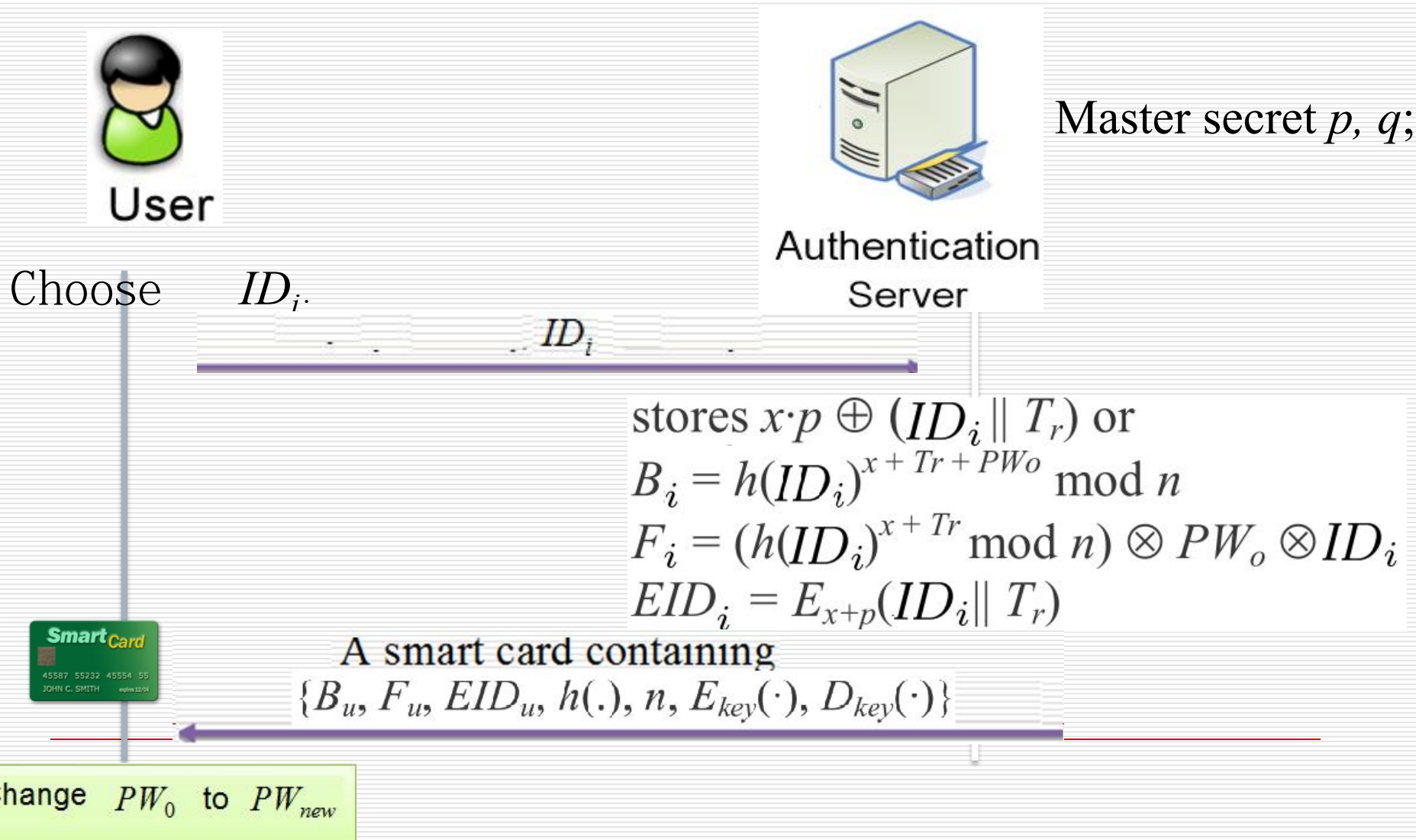
Review of Kumari-Khan's scheme

- Kumari-Khan's scheme
 - the registration phase
 - the login and verification phase
 - the password update phase

Yang, G., Wong, D., Wang, H., Deng, X.: Two-factor mutual authentication based on smart cards and passwords. Int. J. Commun. Syst., 27(12):3939–3955, 2014.

Review of Kumari-Khan's scheme (1/3)

User registration phase



Review of Kumari-Khan's scheme (2/3)

Login and verification phase



Authentication
Server

Input ID_i and PW_i ;
Compute $C_i = B_i / h(ID_i)^{PW_i \bmod n}$;

$$F_i^* = C_i \oplus PW_i \oplus ID_i;$$

Reject if F_i^* does not equal the stored F_i ;

Generate a random number $\alpha \in_R Z_n^*$;

Pick the current timestamp T_i ;

Compute $D_i = h(ID_i)^\alpha \bmod n$;

$$W_i = C_i \cdot D_i \bmod n;$$

$$M_i = h(ID_i \| C_i \| D_i \| W_i \| T_i);$$

$\xrightarrow{EID_i, D_i, M_i, T_i}$

Decrypt L'_s to get $ID'_i \| EID'_i \| W'_i \| T'_s$;

Check the validity of ID'_i and T'_s ;

Check if $W'_i = W_i$ and $EID'_i \neq EID_i$

Update EID_i with EID'_i ;

$\xleftarrow{L_s}$

$[p, q: \text{two large primes such that } p = 2q + 1;$
 $\text{Secret key: } p \text{ and } x \in Z_n^*, \text{ where } n = pq;$

Check the validity of T_i ;

Obtain $ID_i^* \| T_r^*$ by decrypting EID_i using $x + p$;

Reject if $ID_i^* \| T_r^*$ are not in $R_G R$;

Compute $C_i^* = (ID_i^*)^{x+T_r} \bmod n$;

$$W_i^* = C_i^* \cdot D_i \bmod n;$$

Check $M_i^* \stackrel{?}{=} h(ID_i^* \| C_i^* \| D_i \| W_i^* \| T_i)$;

Pick the current timestamp T_s ;

Compute $EID_i^* = E_{x+p}(ID_i \| T_r \| T_s)$;

$$L_s = E_{c_i^*}(ID_i \| EID_i^* \| W_i^* \| T_s);$$

$$sk = h(W_i \| EID_i^*);$$

Update $x \cdot p \oplus (ID_i \| T_r)$ with $x \cdot p \oplus (ID_i \| T_r \| T_s)$;

Review of Kumari-Khan's scheme (3/3)

— Password Change phase

- ❑ Password can be locally changed
- ❑ There is explicit verification of the old pw



User

Change password



Authentication
Server

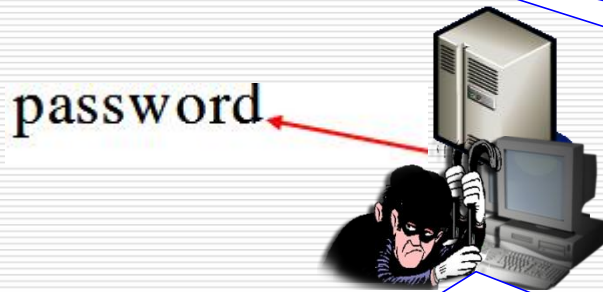
Compute $C_i = (B_i / h(ID_i)^{PW_i}) \bmod n$
 $F_i^* = C_i \otimes PW_i \otimes ID_i$

Check $F_i^* \stackrel{?}{=} \text{stored } F_i$

Compute $(B_i)_{new} = ((B_i / h(ID_i)^{PW_i}) \cdot h(ID_i)^{(PW_i)_{new}}) \bmod n$
 $(F_i)_{new} = (C_i) \otimes (PW_i)_{new} \otimes (ID_i)$
 $(B_i)_{new} \leftarrow B_i, (F_u)_{new} \leftarrow F_i$

Type-II smart-card-loss attack on Kumari-Khan's scheme

$$O(|\mathcal{D}_{id}| * |\mathcal{D}_{pw}| * (T_E + T_I + 2T_H))$$



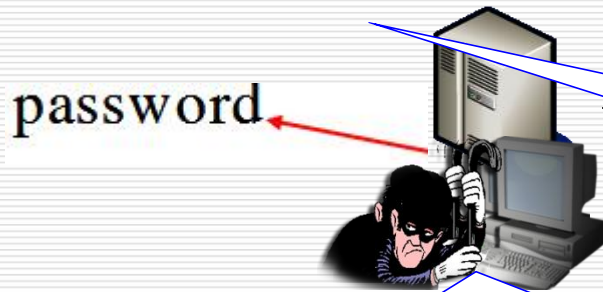
obtains F_i in U_i 's smart card

Costs \$30.56 and 16.47 hours by resorting to the Amazon EC2 C4.4X-large cloud computing service

- Step 1.* Guesses the value of ID_i to be ID_i^* from dictionary space $\mathcal{D}_{id}$ and the value of PW_i to be PW_i^* from dictionary space $\mathcal{D}_{pw}$;
- Step 2.* Computes $C_i^* = B_i / H(ID_i^*)^{PW_i^*} \bmod n$, where B_i is revealed from U_i 's smart card;
- Step 3.* Computes $F_i^* = C_i^* \oplus ID_i^* \oplus PW_i^*$;
- Step 4.* Checks the correctness of (ID_i^*, PW_i^*) by comparing if F_i^* is equal to the extracted F_i ;
- Step 5.* Repeats Step 1, 2, 3 and 4 of this procedure until the correct value of (ID_i^*, PW_i^*) is found.

Type-IV smart-card-loss attack on Kumari-Khan's scheme

$$O(|\mathcal{D}_{id}| * |\mathcal{D}_{pw}| * (T_E + T_I + 2T_H))$$



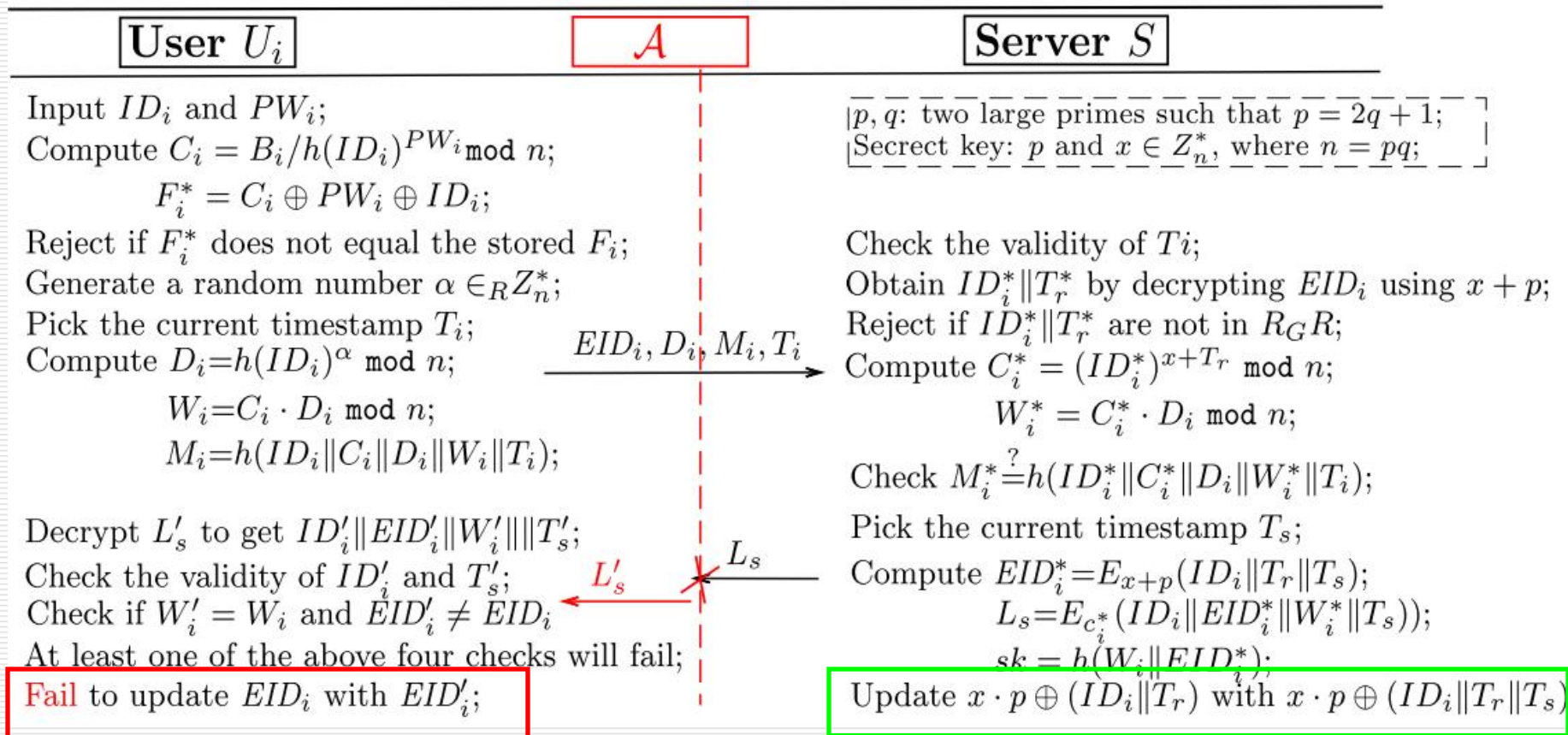
obtains $\{B_i, h(\cdot)\}$ in U_i 's smart card

Intercept $\{D_i, M_i, T_i\}$ from public channel

Costs \$30.56 and 16.47 hours by resorting to the Amazon EC2 C4.4X-large cloud computing service

- Step 1. Guesses the value of ID_i and value of PW_i to be PW_i^* from dictionary space $\mathcal{D}_{pw}$;
- Step 2. Computes $C_i^* = B_i / H(ID_i^*)^{PW_i^*} \bmod n$, where B_i is revealed from U_i 's card;
- Step 3. Computes $W_i^* = C_i^* \cdot D_i$, where D_i is intercepted from the channel;
- Step 4. Computes $M_i^* = H(ID_i^* || C_i^* || D_i || W_i^* || T_i)$, where D_i and T_i is intercepted from the public channel;
- Step 5. Checks the correctness of (ID_i^*, PW_i^*) by comparing if M_i^* is equal to the intercepted M_i ;
- Step 6. Repeats Step 1, 2, 3 and 4 of this procedure until the correct value of (ID_i^*, PW_i^*) is found.

De-synchronization attack on Kumari-Khan's scheme



Desirable attributes

Security requirements

Efficiency

Protocol	Reference	DA1-Strong: No user data stored	DA1-Weak: No password verifier table	DA2-Local-Secure: Password friendly	DA2-Local-Insecure: Password friendly	DA2-Interactive: Password friendly	DA3: No password reveal	DA4: Password dependent	DA5: Mutual authentication	DA6: Session key agreement	DA7: Forward secrecy	DA8-Strong: User identity protection	DA8-Weak: User un-traceability	DA9: Smart card revocation	DA10: timely typo detection	SR1: Resist DoS attack	SR2: Resist impersonation attack	SR3: Resist parallel session attack	SR4: Resist pw guessing attack	SR5: Resist replay attack	SR6-I: Resist card loss attack I	SR6-II: Resist card loss attack II	SR6-III: Resist card loss attack III	SR6-IV: Resist card loss attack IV	SR6-V: Resist card loss attack V	SR6-VI: Resist card loss attack VI	SR6-VII: Resist card loss attack VII	SR6-VIII: Resist card loss attack VIII	SR7: Resist stolen-verifier attack	SR8: Resist reflection attack	SR9: Resist insider attack	Provable security in formal model	User side computational cost	Server side computational cost
Lu et al.(2016)	29	✓	✓	×	✓	×	✓	✓	✓	✓	✓	×	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_E+T_S+4T_H$	$3T_E+3T_H$	
Xie et al.(2016)	54	✓	✓	×	✓	×	×	✓	✓	✓	✓	×	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_E+T_S+4T_H$	$3T_E+3T_H$	
Muhaya(2015)	36	✓	✓	×	✓	×	×	✓	✓	✓	✓	×	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$T_E+T_S+4T_H$	$3T_E+3T_H$	
Jiang et al.(2015)	18	✓	✓	×	×	×	×	✓	✓	✓	✓	×	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$4T_E+T_S+4T_H$	$3T_E+3T_H$	
Wu et al.(2015)	52	×	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$2T_E+2T_S+4T_H$	$3T_E+3T_H$	
ruong et al.(2015)	43	×	✓	✓	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$2T_C+T_S+4T_H$	$3T_E+3T_H$	
Odelu et al.(2015)	38	×	✓	✓	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_E+T_S+4T_H$	$3T_E+3T_H$	
Gishra et al.(2015)	34	×	✓	×	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$2T_E+T_S+4T_H$	$3T_E+3T_H$	
Byun(2015)	5	×	✓	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$5T_E+T_S+2T_H$	$3T_E+3T_H$	
Islam(2014)	17	×	✓	✓	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_E+T_S+4T_H$	$3T_E+3T_H$	
Amari et al.(2014)	21	✓	✓	✓	×	×	✓	✓	✓	✓	✓	×	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$10T_H+T_P+5T_S$	$3T_P+5T_H$	
Tsai et al.(2013)	44	✓	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	T_P+5T_H	$3T_P+5T_H$	
Amari-Khan(2013)	20	×	✓	✓	×	×	×	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$2T_E+T_S+4T_H$	$T_E+2T_S+4T_H$	
Li et al.(2013)	24	✓	✓	✓	×	×	×	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$2T_E+2T_I+4T_H$	T_E+4T_H	
Lee-Liu(2013)	22	×	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	T_E+5T_H	T_E+5T_H	
Li-Zhang(2013)	26	×	✓	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_P+7T_H$	T_P+7T_H	
Wang(2012)	49	×	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$2T_E+T_S+3T_H$	$3T_S+2T_H$	
Wei et al.(2012)	50	✓	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$T_E+T_P+5T_H$	$T_E+T_P+5T_H$	
Zhu(2012)	60	✓	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	T_E+5T_H	T_E+4T_H	
Wang et al.(2011)	48	×	✓	×	×	×	✓	✓	✓	✓	✓	✓	✓	✓	✓	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$4T_P+T_S+6T_H$	$3T_P+T_S+4T_H$	
Li et al.(2010)	25	×	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_S+4T_H$	$3T_P+3T_S+10T_H$	
Song(2010)	40	✓	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	T_S+4T_H	$T_E+T_S+4T_H$	
Sood et al.(2010)	41	✓	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_E+T_I+3T_H$	$2T_E+T_I+3T_H$	
Sun et al.(2009)	42	✓	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$3T_P+6T_H$	$3T_P+5T_H$	
Xu et al.(2009)	55	✓	✓	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	$4T_E+4T_H$	$4T_E+4T_H$	
Guang et al.(2008)	19	×	✓	×	×	×	✓	✓	✓	✓	✓	×	×	×	×	×	✓	✓	✓	✓	×	×	×	×	×	×	×	×	×	×	×	T_S+3T_H	$T_P+2T_S+4T_H$	

Whether with formal proofs

Whether with formal proofs

Note: The timings of T_E , T_I , T_P , T_{m2p} , T_C , T_S and T_H are referred to Table 6. For more measurements, see <http://t.cn/RGH6H3H>.

Conclusion

- ❑ We, for the first time, provide a taxonomy of smart-card-loss attacks.
 - ❑ We show that some critical criteria are unworkable due to a number of ambiguities and redundancies.
 - ❑ We further propose viable fixes and refinements to make an through measurement possible.
 - ❑ We provide a comparative evaluation of 26 two-factor schemes based on the refined metric, highlighting the design challenges and difficulties.
-

THANK YOU

THANK YOU & QUESTIONS

A dilemma

□ The password change attack is simple

- The only assumption made about attacker is that she can get temporary access to the victim's card.

□ How to fix it is tricky

- Suppose an additional parameter $A_i = h(ID_i \parallel h(PW_i))$ is now stored in the card memory.
- Now, an offline guessing attack arises:

□ Our solution

- make an acceptable trade-off

$$h(ID_i^* \parallel h(PW_i^*)) = ? A_i.$$

We compute A_i as $A_i = H(h(PW_i))$, where $h(\cdot): \{0, 1\}^* \rightarrow \{0, 1, 2, \dots, 255\}$

Effectiveness of our solution

Table 1. Guessing entropy (GE) distributions of password datasets that are randomly divided into 256 equally-sized password pools

Password datasets	Percentage of pools with $GE \geq 1024$
Rockyou_Top1Million	0.00%
CSDN_Top1Million	10.54%
Rockyou_Top2Million	84.63%
CSDN_Top2Million	97.66%
Rockyou_Top x Million($x \geq 3$)	99.60%
CSDN_Top x Million($x \geq 3$)	100.00%

$$GE = \sum_{i=1}^N p_i \cdot i$$

Outline

- ☐ Introduction
- ☐ System model and adversary model
- ☐ Attacks on Yang et al.'s scheme
- ☒ Attack on Li et al.'s scheme
- ☐ Conclusion

Attacking Li et al.'s PSCAV

□ Our attack on Yang et al.'s scheme

- Exploits a vulnerability in the password change phase
- Assumes the attacker has got the victim's card
- Consequence: the card cannot be usable

□ The following attack on Li et al.'s scheme

- Exploits a vulnerability in the login phase
 - Assumes the attacker can control the communication channel
 - Consequence: the card cannot be usable
-

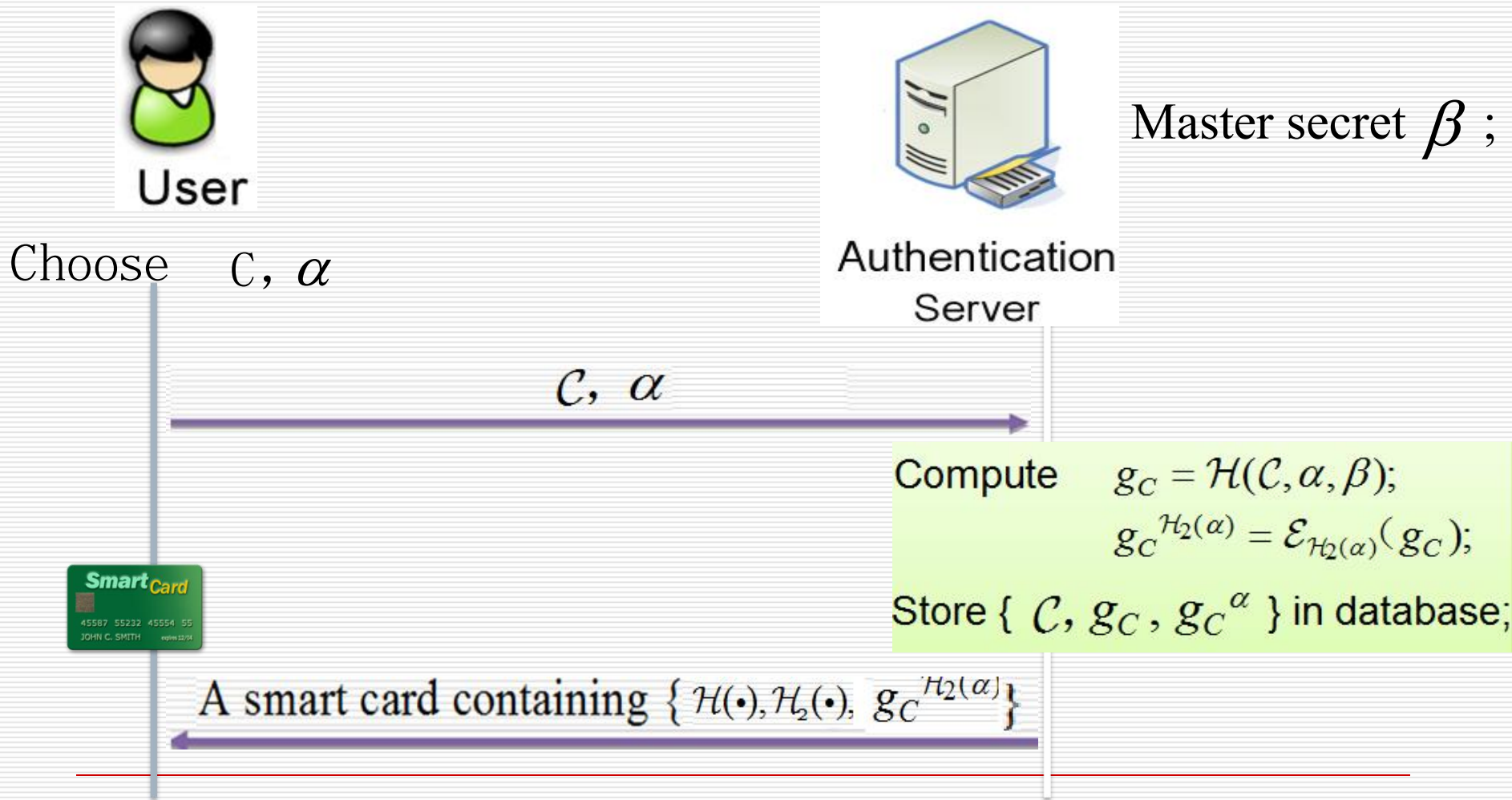
Review of Li et al.'s PSCAV

- Li et al.'s PSCAV
 - the registration phase
 - the pre-computation phase
 - the login and verification phase
 - password change phase

Li, X., Qiu, W., Zheng, D., Chen, K., Li, J.: Anonymity enhancement on robust and efficient password-authenticated key agreement using smart cards. IEEE Trans. Ind. Electron. 57(2), 793–800 (2010)

Review of Wang's scheme (1/2)

— User registration



Review of Wang's scheme(2/2)

— Login and verification phase



Pre-computation phase:

Compute $e = rG, c = rP_S$;

Login phase:

Input PW_i ; Retrieve $\{e, c, V_{ID_i}, b_{ID_i}^{N_0}\}$;
Generate a random $N_1 \in_R \{0, 1\}^{64}$;

Decrypt $b_{ID_i}^{N_0}$ to obtain $\{ID_i, CI_i, N_0, \dots\}$;
Reject if no record matching $\{ID_i, CI_i, N_0\}$;
Compute $V_{ID_i} = h(ID_i \| s \| CI_i)$;
Obtain $\{N_1, e\}$ by decrypting $E_{V_{ID_i}}(N_1 \| e)$;

Update $\{ID_i, CI_i, N_0\}$ to $\{ID_i, CI_i, N_1\}$;

Generate a random $u \in_R \{0, 1\}^{64}$;
Compute $c = xe, M_S = h(c \| u \| V_{ID_i})$;
 $b_{ID_i}^{N_1} = E_s((ID_i \| CI_i \| N_1) \dots)$;
 $N_{b1} = b_{ID_i}^{N_1} \oplus (h(N_1 \| e \| 1) \dots)$;
 $M_S = h(c \| u \| V_{ID_i})$;

Compute $M_S = h(c \| u \| V_{ID_i})$;

Reject due to $M_S \neq X$; $M_S, N_{b1}, u \oplus h_{64}(b_{ID_i}^{N_1})$

Update $b_{ID_i}^{N_0}$ with $b_{ID_i}^{N_1}$;

De-synchronization attack on Li et al.'s scheme

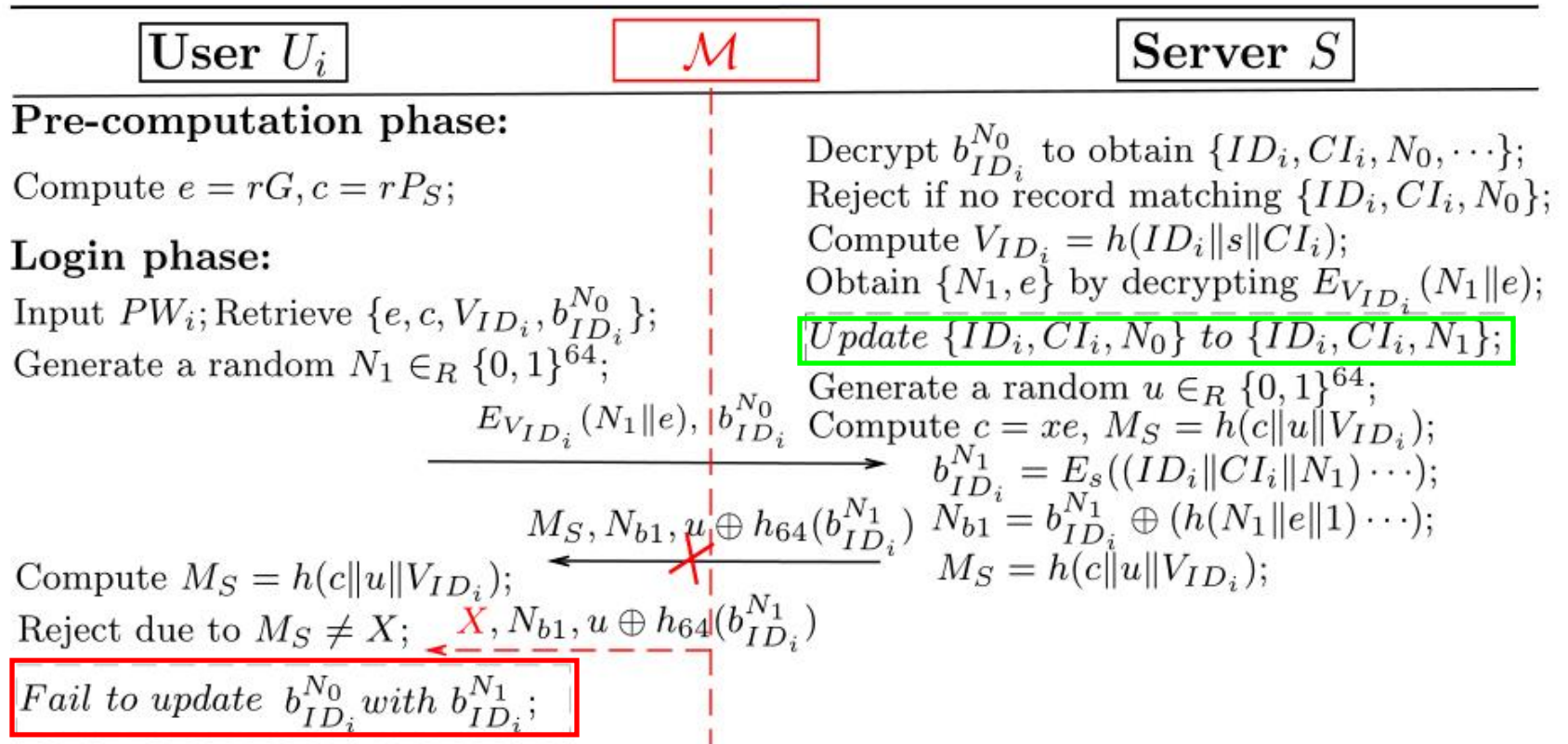


Fig. 1. De-synchronization attack on Li et al.'s scheme

Discussions on countermeasures

□ Attacking consequences

— The card is completely unable

□ Fixes

- S defers replacing $\{ID_i, CI_i, N_0\}$ with $\{ID_i, CI_i, N_1\}$ in its database until having received the expected third message flow from U_i .
 - **Store** both $b_{ID_i}^{N_0}$ and $b_{ID_i}^{N_1}$ on the card memory.
-

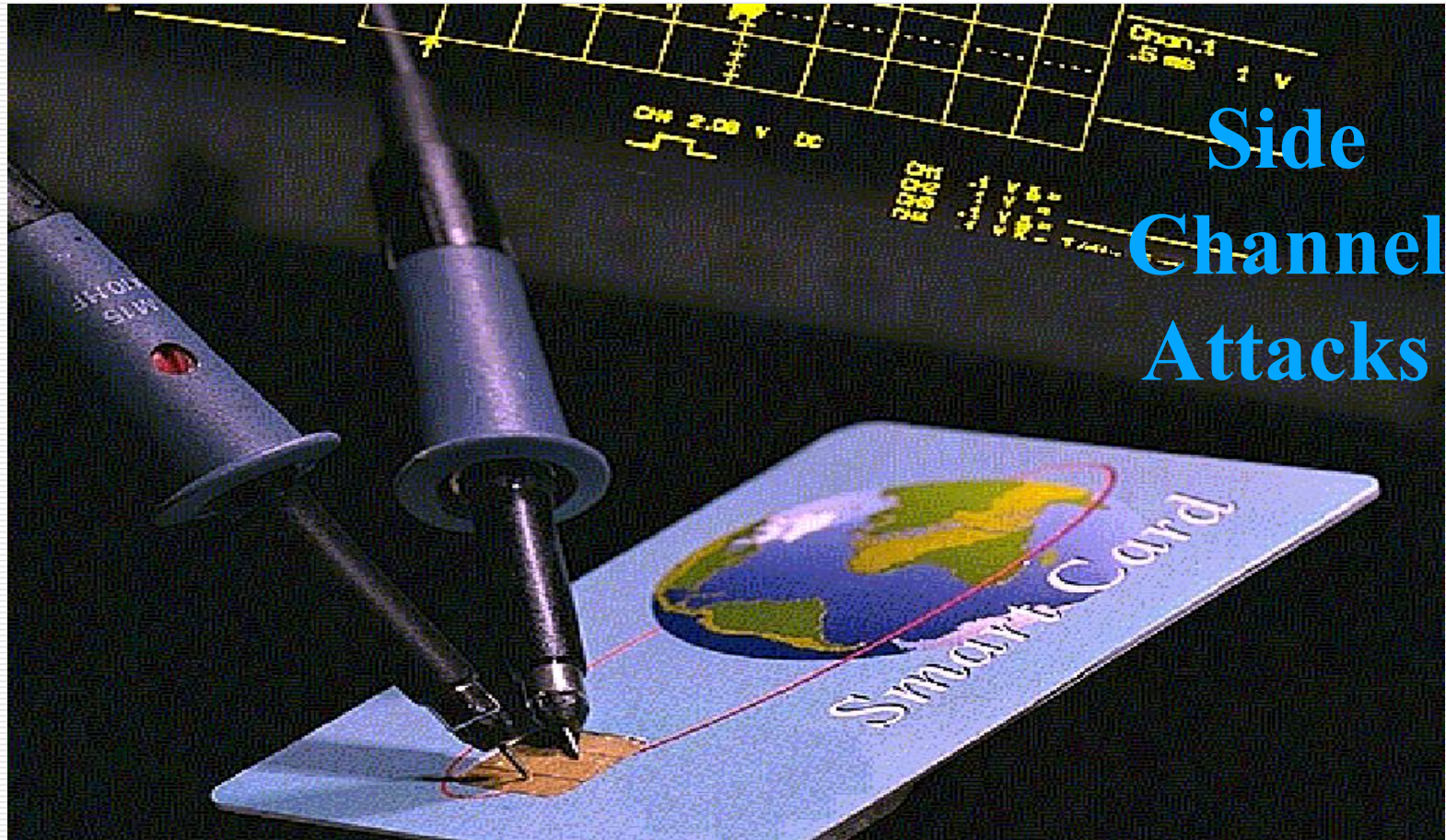
Conclusion

- We introduce the concept of two-factor authentication, and elaborate on the challenges in designing this type of schemes.
 - Two practical attacks are demonstrated on Hsieh-Leu's scheme and Wang's scheme, respectively.
 - Two new security threats on two-factor authentication are highlighted:
 - Password change attack
 - De-synchronization attack
-

THANK YOU

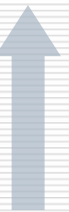
THANK YOU & QUESTIONS

Side-Channel Attack



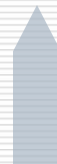
Various attacks

- ☐ Offline password guessing attack
- ☐ Smart card loss attack
- ☐ Stolen verifier attack
- ☐ User impersonation attack
- ☐ Server masquerading attack
- ☐ Replay attack
- ☐ Parallel session attack
- ☐ Denial of service attack
- ☐ Password disclosure to server (Insider attack)
- ☐ Forward secrecy
- ☐ Key compromise impersonation attack
- ☐ Unknown key share attack
- ☐ ...



Functionalities

- ☐ key agreement
 - ☐ mutual authentication
 - ☐ local password change
 - ☐ user anonymity (initiator un-traceability)
 - ☐ no verifier table
 - ☐ support weak password
 - ☐ non-tamper resistant smart cards
 - ☐ repairability
-



Performance

- ❑ Computation complexity (a big hill)

cryptographic operations are often computation-intensive, like modular exponentiation, modulo inversion, pairing ...

- ❑ Storage cost (not a big problem)

- ❑ Communication overhead (not a big problem)

